

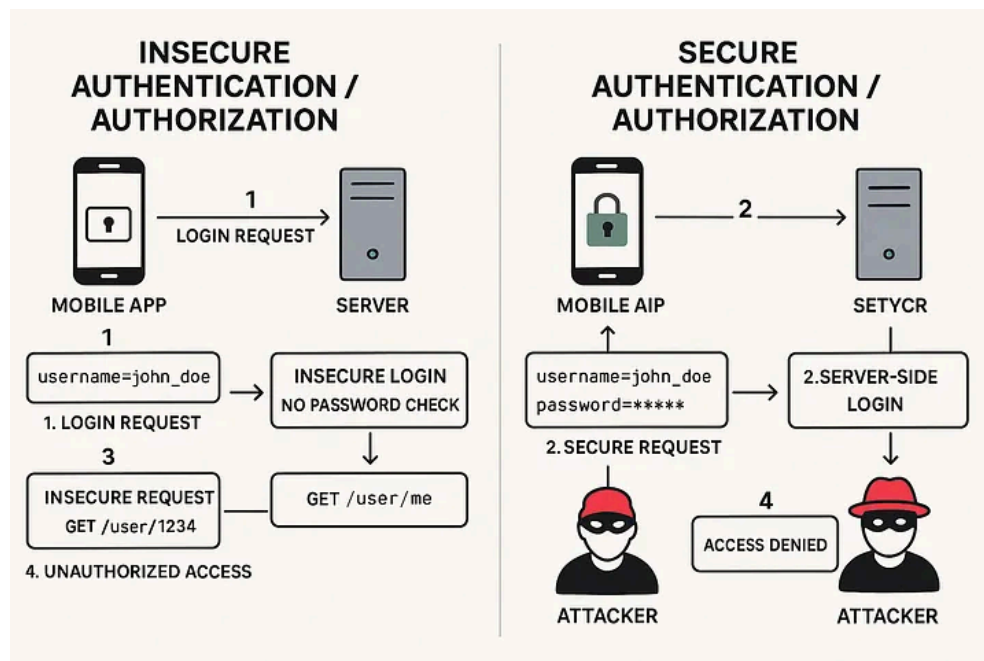
Insecure Authentication, Authorization & Communication

Introduction

What is Insecure Authentication, Authorization, and Communication?

According to mobile security research and standards:

Authentication verifies identity, while authorization determines the permissions an authenticated user has. Insecure versions of these processes occur when weaknesses allow unauthorized access or privilege escalation. Insecure communication involves transmitting data over unsecured channels, such as cleartext HTTP or improperly configured TLS, risking interception by malicious actors.



Vulnerabilities and Root Causes

- **Insecure Authentication Methods**
 - Vulnerabilities arise from weak password policies, missing access tokens like JWT, a lack of multi-factor authentication (MFA), and broken session management.
- **Insecure Authorization and Communication**
 - Issues include Insecure Direct Object References (IDOR), privilege escalation via improper role transmission, and cleartext communication without SSL/TLS.

What is the impact of these issues?

- **Unauthorized Access and Data Compromise**
 - Attackers can bypass authentication to access databases, leading to massive data breaches and unauthorized transactions.
- **Privilege Escalation and Interception**
 - Users can escalate their privileges to perform restricted actions, while insecure communication allows for Man-in-the-Middle (MitM) attacks.

Case Study

Exploiting Insecure Direct Object Reference (IDOR)

A fitness tracking application exposes user profiles through a sequential ID in the URL, such as `/api/v1/profile/1001`, without verifying if the authenticated user owns that ID.

The Vulnerability (Broken Authorization)

The application fails to implement a check on the server side to ensure that the user requesting the profile data has the authorization to view it. This is a classic IDOR vulnerability.

The Attack

An attacker logs into their own account and then uses an automated script to iterate through IDs (`/profile/1002`, `/profile/1003`, etc.). By observing the responses, the attacker can harvest sensitive personal data of thousands of users.

Result

The attacker successfully performs a large-scale data scrape, demonstrating how missing object-level access control (BOLA) can lead to severe privacy violations and reputational damage.

Practical (setting up frida server)

frida-server-17.9.10-android-x86.xz	0	sha256:3...	19.2 MB	5 days ago
frida-server-17.9.10-android-x86_64.xz	0	sha256:3...	30.2 MB	5 days ago
frida-server-17.9.10-linux-arm64-musl.xz	0	sha256:6...	9.13 MB	5 days ago

```
>>>> ~/Shells/frida
• [avd] Z> python3 -m venv venv
```

```
>>>> ~/Shells/frida
• [avd] Z> source venv/bin/activate

>>>> ~/Shells/frida via v3.12.3 (venv)
• [avd] Z>
```

```
>>>> ~/Shells/frida via v3.12.3 (venv)
• [avd] Z> pip install frida-tools
Requirement already satisfied: frida-tools in ./venv/lib/python3.12/site-packages (14.8.2)
Requirement already satisfied: colorama<1.0.0,>=0.2.7 in ./venv/lib/python3.12/site-packages (from frida-tools) (0.4.6)
Requirement already satisfied: frida<18.0.0,>=17.9.0 in ./venv/lib/python3.12/site-packages (from frida-tools) (17.9.10)
Requirement already satisfied: prompt-toolkit<4.0.0,>=2.0.0 in ./venv/lib/python3.12/site-packages (from frida-tools) (3.0.52)
Requirement already satisfied: pygments<3.0.0,>=2.0.2 in ./venv/lib/python3.12/site-packages (from frida-tools) (2.20.0)
Requirement already satisfied: websockets<14.0.0,>=13.0.0 in ./venv/lib/python3.12/site-packages (from frida-tools) (13.1)
Requirement already satisfied: wcwidth in ./venv/lib/python3.12/site-packages (from prompt-toolkit<4.0.0,>=2.0.0->frida-tools) (0.7.0)

>>>> ~/Shells/frida via v3.12.3 (venv)
• [avd] Z>
```

```
>>>> ~/Shells/frida via v3.12.3 (venv)
• [avd] Z> wget https://github.com/frida/frida/releases/download/17.9.10/frida-server-17.9.10-android-x86_64.xz
--2026-05-20 18:15:28-- https://github.com/frida/frida/releases/download/17.9.10/frida-server-17.9.10-android-x86_64.xz
Resolving github.com (github.com)... 64:ff9b::14cf:4952, 20.207.73.82
Connecting to github.com (github.com)[64:ff9b::14cf:4952]:443... connected.
HTTP request sent, awaiting response...
```

```

>>>> ~/Shells/frida via 🐙 v3.12.3 (venv)
• [avd] Z> adb root
adb is already running as root

>>>> ~/Shells/frida via 🐙 v3.12.3 (venv)
• [avd] Z> adb push frida-server /data/local/tmp/
frida-server: 1 file pushed, 0 skipped. 224.5 MB/s (110833224 bytes in 0.471s)

>>>> ~/Shells/frida via 🐙 v3.12.3 (venv)
• [avd] Z> adb shell "chmod 755 /data/local/tmp/frida-server"

>>>> ~/Shells/frida via 🐙 v3.12.3 (venv)
• [avd] Z> adb shell "/data/local/tmp/frida-server &"

```

```

>>>> ~/Shells/frida via 🐙 v3.12.3 (venv)
• [avd] Z> frida-ps -U

```

PID	Name
2941	Camera
2637	Chrome
2816	Files
1679	Google
3649	Messages
3390	Personal Safety
1272	SIM Toolkit
1284	Settings
4421	adb
213	android.hardware.atrace@1.0-service
412	android.hardware.audio.service
436	android.hardware.authsecret-service.example
1038	android.hardware.biometrics.face-service.example
1033	android.hardware.biometrics.fingerprint-service.ranchu
425	android.hardware.bluetooth-service.default
413	android.hardware.camera.provider.ranchu
414	android.hardware.camera.provider@2.7-service-google
437	android.hardware.cas-service.example
426	android.hardware.contexthub-service.example
448	android.hardware.drm-service.widevine
415	android.hardware.gatekeeper@1.0-service.software
1129	android.hardware.gnss-service.ranchu
416	android.hardware.graphics.allocator@3.0-service.ranchu
427	android.hardware.graphics.composer3-service.ranchu
417	android.hardware.health-service.example
428	android.hardware.identity-service.example
429	android.hardware.lights-service.example

Mitigations

- **Implement Strong Protocols**

- Use modern authentication protocols like OIDC and ensure multi-factor authentication (MFA) is enforced.

- **Enforce Server-Side Checks**

- Always verify user permissions on the server for every request to prevent IDOR and privilege escalation.

- **Secure Communication Channels**

- Utilize TLS 1.2+ for all transmissions and implement SSL pinning to prevent MitM attacks.

Conclusion

Insecure Authentication, Authorization, and Communication are among the most impactful mobile vulnerabilities. By neglecting identity verification, permission checks, or data encryption, developers leave apps open to data theft and account takeovers. A robust security posture requires a multi-layered approach: strong authentication mechanisms, rigorous server-side authorization, and end-to-end encrypted communication.

References

[OWASP Mobile Top 10 Project](#)

<https://github.com/frida/frida>

<https://frida.re/docs/android/>